

PLANTILLA EXCEL: CÁLCULO IGM-CAPEC Y ROI DE CIBERSEGURIDAD

Guía de Implementación y Descripción de Hojas de Cálculo

Kit de Encuesta CAPEC-ESP • Documento E • Versión 1.0 • Abril 2026

«Los datos sin fórmulas son anécdotas. Las fórmulas sin datos son filosofía. La hoja de cálculo es el punto donde se reconcilian.»

DESCRIPCIÓN GENERAL DEL ARCHIVO

Nombre del archivo: CAPEC-ESP-IGM-ROI-Calculator-v1.0.xlsx

El libro de cálculo contiene **8 hojas de trabajo** organizadas en flujo secuencial:

INSTRUCCIONES → ENCUESTA_DATOS → IGM_CAPEC → ROSI_CALCULATOR
→ BENCHMARK_SECTORIAL → DASHBOARD_EJECUTIVO → PLAN_ACCION → REFERENCIAS

HOJA 1: INSTRUCCIONES

Propósito: Guía de uso del libro completo.

Contenido:

- Diagrama de flujo de uso (cómo pasar datos de una hoja a otra)
- Convenciones de color de celda:
 -  Amarillo: celdas de entrada de datos manuales
 -  Verde: celdas de cálculo automático (no modificar)
 -  Azul: celdas de fórmulas de referencia cruzada
 -  Rojo: alertas de umbrales críticos superados
- Versión, fecha y créditos

HOJA 2: ENCUESTA_DATOS

Propósito: Entrada bruta de respuestas individuales por organización.

Estructura de columnas:

Col	Campo	Tipo	Descripción
A	ID_Encuesta	Texto	Código alfanumérico anónimo (ej: ESP-2026-001)
B	Fecha_Respuesta	Fecha	DD/MM/AAAA
C	Sector	Lista desplegable	13 sectores predefinidos
D	Tamaño	Lista desplegable	5 rangos de empleados
E	Marco_ENS	Booleano (0/1)	Sujeto a ENS (Sí=1, No=0)
F	Marco_NIS2_Esencial	Booleano (0/1)	Entidad esencial NIS2
G	Marco_NIS2_Importante	Booleano (0/1)	Entidad importante NIS2
H	Marco_DORA	Booleano (0/1)	Bajo DORA
I	Marco_ISO27001	Booleano (0/1)	Certificación ISO 27001
J-M	Presupuesto_TI_Pct	Lista desplegable	% ciberseguridad / TI total (5 rangos)
N	P1_1_Familiaridad_Personal	Escala 1-5	Conocimiento CAPEC personal
O	P1_2_Familiaridad_Org	Escala 1-5	Conocimiento CAPEC organizacional
P	P1_4_Likelihood_Of_Attack	Escala 1-5	Uso de indicador CAPEC
Q	P1_4_Typical_Severity	Escala 1-5	Uso de indicador CAPEC
R	P1_5_Estado_Impl	Escala 1-5	Estado de implementación CAPEC
S	P2_1_Modelado	Escala 1-5	Madurez del modelado de amenazas
T	P2_2_Integración	Escala 1-5	Integración CAPEC-modelado
U-AB	P3_5_Dom_SW a P3_5_Dom_OT	Escala 1-5 cada uno	Madurez IGM por 7 dominios CAPEC
AC	P3_1_Metricas_CAPEC	Recuento (0-10)	Número de métricas CAPEC implementadas
AD	P3_3_Reporte_Consejo	Escala 1-5	Frecuencia de reporte al Consejo
AE	P3_4_Indicadores_Riesgo	Escala 1-5	Integración en gestión de riesgos
AF	P4_2_IA_Control	Promedio 1-5 (6 subtipos)	Controles adversariales IA
AG	P4_4_SupplyChain	Recuento (0-9)	Prácticas supply chain implementadas
AH	P4_6_PQC	Escala 1-5	Preparación post-quantum

AI	P5_2_NIS2_Impacto	Escala 1-5	Impacto NIS2 en adopción CAPEC
AJ	P6_1_BCP_DRP	Escala 1-5	CAPEC en continuidad de negocio
AK	P6_2_Tabletop	Escala 1-5	Frecuencia de ejercicios
AL-AQ	P6_3_RTO a P6_3_Contencion	Escala 1-5 cada uno	6 métricas de resiliencia
AR	P9_1_ZeroTrust	Escala 1-5	Estado de Zero Trust
AS	Coste_Incidentes_12m	Numérico (EUR)	Coste total de incidentes último año
AT	Budget_Ciberseguridad_EUR	Numérico (EUR)	Presupuesto anual de ciberseguridad

HOJA 3: IGM_CAPEC

Propósito: Cálculo automático del Índice Global de Madurez CAPEC por organización y agregado.

Sub-índices calculados

IGC — Índice de Gestión del Conocimiento (peso: 25%)

```
=PROMEDIO(
    N2,          [P1_1_Familiaridad_Personal – escala directa]
    O2,          [P1_2_Familiaridad_Org – escala directa]
    SI(R2>=4,5, SI(R2>=3,3, SI(R2>=2,2,1))), [P1_5_Estado_Impl codificado]
    S2,          [P2_1_Modelado]
    T2           [P2_2_Integracion]
) / 5
```

Fórmula simplificada en Excel:

```
=PROMEDIO(N2,O2,R2,S2,T2)/5
```

ICM — Índice de Cobertura de Métricas (peso: 20%)

```
=PROMEDIO(
    MIN(AC2/10*5, 5), [P3_1_Metricas: normalizado 0-10 → 1-5]
    AD2,              [P3_3_Reporte_Consejo]
    AE2,              [P3_4_Indicadores_Riesgo]
    PROMEDIO(U2:AB2) [P3_5_IGM_Dominios: promedio de 7 dominios]
) / 4
```

IAR — Índice de Alineación Regulatoria (peso: 20%)

```
=PROMEDIO(
    E2*5,          [Marco_ENS: binario → peso 5 si sí]
    F2*4+G2*3,    [NIS2 Esencial=4pts, Importante=3pts]
    AI2,           [P5_2_NIS2_Impacto]
    SI(H2=1,4,1)   [DORA_cumplimiento: básico 1, bajo DORA 4]
) / 4
```

IRD — Índice de Resiliencia Digital (peso: 20%)

```
=PROMEDIO(
  AJ2,          [P6_1_BCP_DRP]
  AK2,          [P6_2_Tabletop]
  PROMEDIO(AL2:AQ2) [P6_3_Metricas_Resiliencia: 6 indicadores]
) / 3
```

IBE — Índice de Brecha Emergente (peso: 15%)

```
=PROMEDIO(
  AF2,          [P4_2_IA_Controlles]
  MIN(AG2/9*5,5), [P4_4_SupplyChain: normalizado 0-9 → 1-5]
  AH2,          [P4_6_PQC]
  AR2           [P9_1_ZeroTrust]
) / 4
```

Cálculo del IGM-CAPEC Global

```
=REDONDEAR(
  0.25 * IGC
  + 0.20 * ICM
  + 0.20 * IAR
  + 0.20 * IRD
  + 0.15 * IBE,
2)
```

Clasificación automática del nivel de madurez

```
=SI(IGM_CAPEC < 0.20, "1 — INICIAL",
  SI(IGM_CAPEC < 0.40, "2 — EN DESARROLLO",
    SI(IGM_CAPEC < 0.60, "3 — DEFINIDO",
      SI(IGM_CAPEC < 0.80, "4 — GESTIONADO",
        "5 — OPTIMIZADO")))))
```

Tabla de resultados por organización

Columna	Contenido	Tipo
ID	Código anónimo de encuesta	Texto
Sector	Sector de actividad	Texto
Tamaño	Rango de empleados	Texto
IGC	Sub-índice de conocimiento	Decimal 0-1
ICM	Sub-índice de métricas	Decimal 0-1
IAR	Sub-índice normativo	Decimal 0-1
IRD	Sub-índice resiliencia	Decimal 0-1
IBE	Sub-índice emergente	Decimal 0-1
IGM_CAPEC	Índice global	Decimal 0-1
Nivel_Madurez	Etiqueta descriptiva	Texto
Alerta_Brechas	Dominios con IGM < 0.40	Texto

HOJA 4: ROSI_CALCULATOR

Propósito: Calcular el Return on Security Investment (ROSI) y el modelo FAIR de pérdida esperada.

Sección A: Parámetros de entrada

Campo	Celda	Descripción	Unidad
ALE_sin_control	C5	Annualized Loss Expectancy sin controles CAPEC	EUR
ALE_con_control	C6	ALE estimada con controles CAPEC implementados	EUR
Budget_Ciberseguridad	C7	Presupuesto anual de ciberseguridad	EUR
Coste_Incidentes_12m	C8	Coste real de incidentes en el último año	EUR
Tasa_Reducción_Riesgo	C9	% de reducción de riesgo estimada por controles	%
Factor_Amortizacion	C10	Años de vida útil de los controles implementados	Años

Sección B: Modelo de Pérdida Esperada (FAIR simplificado)

```
# ALE (Annualized Loss Expectancy)
ALE = Frecuencia_Anual_Incidentes × Magnitud_Media_Pérdida

# Frecuencia Anual = TEF (Threat Event Frequency) × Vulnerabilidad
TEF_estimado = (Incidentes_sector_12m / Organizaciones_sector) × Factor_Criticidad

# Magnitud Pérdida = Coste_Directo + Coste_Indirecto + Coste_Reputacional
Coste_Directo = Respuesta_incidente + Recuperación_sistemas + Notificación
Coste_Indirecto = Paralización_negocio × Horas_parada + Pérdida_ingresos
Coste_Reputacional = Pérdida_clientes_estimada × Valor_cliente_medio × 3_años
```

Sección C: Cálculos automáticos ROSI

```
# Beneficio neto anual de los controles de seguridad
Beneficio_Neto = (ALE_sin_control - ALE_con_control) × Tasa_Reducción_Riesgo / 100

# ROSI como porcentaje
ROSI_Porcentaje = ((Beneficio_Neto - Budget_Ciberseguridad) / Budget_Ciberseguridad) × 100

# ROSI como fórmula Excel en C15:
=((C5-C6)*C9/100 - C7) / C7 * 100

# Payback Period (meses)
=REDONDEAR((C7 / (Beneficio_Neto / 12)), 0)
```

Sección D: Escenarios de simulación (tabla de sensibilidad)

La hoja incluye una tabla de doble entrada que cruza:

- **Eje X:** Nivel de madurez IGM-CAPEC (1-5)
- **Eje Y:** Presupuesto de ciberseguridad (% sobre TI: 5%, 10%, 15%, 20%)

Con celdas de formato condicional que marcan en verde los escenarios con ROSI > 200% y en rojo los < 50%.

Sección E: Estimación de sanciones regulatorias evitadas

NIS2 - Sanción máxima

Sancion_NIS2_Esencial = $0.02 \times \text{Facturacion_Global_Anual}$ (Art. 32)

Sancion_NIS2_Importante = $0.014 \times \text{Facturacion_Global_Anual}$ (Art. 33)

RGPD

Sancion_RGPD = $\text{MAX}(20.000.000, 0.04 \times \text{Facturacion_Global_Anual})$

DORA (Art. 50)

Sancion_DORA = Variable según infracción específica

Fórmula de riesgo regulatorio total evitado:

Beneficio_Regulatorio = $(\text{Probabilidad_Sancion_Sin_Control} - \text{Probabilidad_Sancion_Con_Control}) \times \text{Sancion_Estimada}$

HOJA 5: BENCHMARK_SECTORIAL

Propósito: Tabla de benchmarking por sector para comparar el IGM-CAPEC de la organización con la media del sector.

Estructura de la tabla de benchmark

Sector	IGM Medio	IGC Medio	ICM Medio	IAR Medio	IRD Medio	IBE Medio	N Organizaciones
Banca / Financiero	=PROMEDIO(...)	...	...	...	...	...	=CONTAR(...)
Energía	...						
Salud	...						
AA.PP.	...						
Telecos	...						
Transporte	...						
Tecnología	...						
Fabricación/OT	...						
Otros	...						
TOTAL ESPAÑA	=IGM_Global						=N_Total

Posición relativa

La hoja calcula automáticamente para cada organización:

```
# Percentil de la organización respecto a su sector  
=RANGO.PERCENTIL(IGM_Sector, IGM_Org, 1)  
  
# Distancia al liderazgo sectorial (percentil 75)  
=PERCENTIL(IGM_Sector, 0.75) - IGM_Org  
  
# Etiqueta de posición:  
=SI(Percentil>=75, "Líder sectorial",  
  SI(Percentil>=50, "Por encima de la media",  
    SI(Percentil>=25, "En la media",  
      "Por debajo de la media – acción prioritaria")))
```

HOJA 6: DASHBOARD_EJECUTIVO

Propósito: Panel visual de una página para presentar ante el Consejo de Administración.

Componentes del dashboard

Bloque 1: IGM-CAPEC Score Card

- Gauge chart con el IGM-CAPEC global (0–1) y la etiqueta del nivel de madurez
- Indicadores de variación interanual (flecha ↑↓ si hay datos del año anterior)

Bloque 2: Araña de Sub-Índices

- Gráfico de radar (spider chart) con los 5 sub-índices: IGC, ICM, IAR, IRD, IBE
- Superposición de la línea de benchmark sectorial

Bloque 3: Madurez por Dominio CAPEC

- Barras horizontales para los 7 dominios con semáforo de colores:
 -  IGM < 0.40 — brechas críticas
 -  IGM 0.40–0.60 — en desarrollo
 -  IGM > 0.60 — gestionado

Bloque 4: ROSI Ejecutivo

- KPI de inversión anual en seguridad (EUR)
- KPI de ROSI calculado (%)
- KPI de sanciones regulatorias evitadas estimadas (EUR)
- KPI de periodo de recuperación de la inversión (meses)

Bloque 5: Top 3 Brechas Prioritarias

- Lista automática de los 3 dominios con menor IGM-CAPEC
- Recomendación de acción vinculada al Plan de Acción (Hoja 7)

HOJA 7: PLAN_ACCION

Propósito: Plantilla de plan de acción priorizado automáticamente según las brechas detectadas.

Estructura de la tabla de acciones

ID	Brecha detectada	Dominio CAPEC	Patrón (es) clave	Acción recomendada	Marco normativo	Prioridad	Plazo estimado	Responsable	Estado	Coste estimado EUR
AC-001	IGM-Software < 0.40	Software	CAPEC-63, CAPEC-86	Implementar SAST/DAST en pipeline CI/CD	NIS2 Art.21.2.e / ENS M.op.p 1.1	CRÍTICA	3 meses	Dev-Sec Lead	Pendiente	
AC-002	Sin política IA generativa	Ingeniería Social	CAPEC-163, CAPEC-98	Redactar y aprobar política de uso de IA generativa	NIS2 Art.21.2.h / ISO 42001	ALTA	1 mes	CISO	Pendiente	
AC-003	HNDL sin estrategia	Comunicaciones	CAPEC (nueva entrada)	Iniciar inventario criptográfico y evaluación PQC	ENS M.mp.com.2 / NIST FIPS 203	ALTA	6 meses	Arquitecto Seguridad	Pendiente	
AC-004	Sin SBOM	Supply Chain	CAPEC-437, CAPEC-538	Generar SBOM automatizado con herramienta SCA	NIS2 Art.21.2.d / DORA Art.28	ALTA	2 meses	DevOps Lead	Pendiente	

HOJA 8: REFERENCIAS

Propósito: Tabla de referencia de patrones CAPEC más relevantes para cada dominio.

Tabla de patrones CAPEC de referencia

CAPEC-ID	Nombre	Dominio	Likelihood _Of_Attack	Typical_Severity	Mecanismo	Controles mínimos	Mapeo ATT&CK
CAPEC-63	Cross-Site Scripting (XSS)	Software	Alto	Alto	Inject Unexpected Items	CSP, Input validation, Output encoding	T1059.007
CAPEC-62	Cross-Site Request Forgery	Software	Medio	Alto	Abuse of Functionality	CSRF tokens, SameSite cookies	T1185
CAPEC-98	Phishing	Ing. Social	Alto	Alto	Deceptive Interactions	DMARC/ SPF/ DKIM, MFA, user training	T1566
CAPEC-163	Spear Phishing	Ing. Social	Alto	Muy Alto	Deceptive Interactions	Executive protection , AI-detection tools	T1566.002
CAPEC-437	Supply Chain	Supply Chain	Medio	Muy Alto	Manipulate System Resources	SBOM, SCA, CI/CD hardening	T1195
CAPEC-538	Open Source SW Manipulation	Supply Chain	Medio	Alto	Manipulate System Resources	Dependency pinning, private registry	T1195.001
CAPEC-695	Repo Jacking	Supply Chain	Medio	Alto	Manipulate System Resources	Namespaces protection , monitoring	T1195.001
CAPEC-21	Abuse of Trusted Credentials	Comunicaciones	Alto	Muy Alto	Gain Privileges	MFA, PAM, Zero Trust	T1550
CAPEC-633	Token Impersonation	Comunicaciones	Medio	Muy Alto	Gain Privileges	Token binding, short-lived tokens	T1134

CAPEC-186	Malicious Software Update	Supply Chain	Bajo	Muy Alto	Manipulate System Resources	Signature verification, SBOM	T1195.002
CAPEC-34	HTTP Response Splitting	Software	Medio	Medio	Inject Unexpected Items	HTTP security headers	T1059

INSTRUCCIONES DE IMPLEMENTACIÓN RÁPIDA

Paso 1: Importar datos de la encuesta

1. Abrir la hoja ENCUESTA_DATOS
2. Pegar las respuestas exportadas de Google Forms / LimeSurvey / Qualtrics
3. Asegurarse de que los campos numéricos tienen formato numérico (no texto)

Paso 2: Verificar cálculos automáticos

4. Ir a la hoja IGM_CAPEC
5. Verificar que las fórmulas calculan correctamente para las primeras 5 filas
6. Si aparece #¡REF! o #¡VALOR!, revisar la hoja INSTRUCCIONES para depuración

Paso 3: Personalizar benchmark

7. Si tiene datos sectoriales previos, introducirlos en BENCHMARK_SECTORIAL columna "Media Referencia"
8. Los percentiles se calcularán automáticamente

Paso 4: Generar dashboard

9. La hoja DASHBOARD_EJECUTIVO se actualiza automáticamente
10. Exportar a PDF: Archivo → Exportar → Crear PDF/XPS (diseñada para formato A4 apaisado)

Paso 5: Priorizar acciones

11. La hoja PLAN_ACCION mostrará automáticamente las 5 brechas más críticas
12. Asignar responsables y fechas en las columnas correspondientes

NOTAS DE COMPATIBILIDAD

- Compatible con Microsoft Excel 365 / 2021 / 2019 y Google Sheets
- Las tablas dinámicas requieren actualización manual: Datos → Actualizar todo
- Los gauge charts requieren Excel 365 o la instalación del complemento correspondiente en versiones anteriores
- En Google Sheets, algunas funciones avanzadas (RANGO.PERCENTIL, anidamientos complejos) pueden requerir adaptación a la sintaxis de Sheets